

# OPMS Security Documentation

---

Authentication, authorization, rate limits / 15-min IP block, secrets, edge TLS, and hardening plan

Generated: 2026-09-22

Diagrams rendered with Mermaid 11 · Secrets redacted

# Contents

---

08-security/01-security-overview.md  
08-security/02-threat-model.md  
08-security/03-data-protection-and-ops.md  
08-security/04-authorization-model.md  
02-architecture/07-authentication-authorization.md  
04-api/02-authentication.md  
03-functional/authentication.md  
06-developer-deployment/19-security.md  
06-developer-deployment/05-environment-variables.md

# OPMS Security Documentation

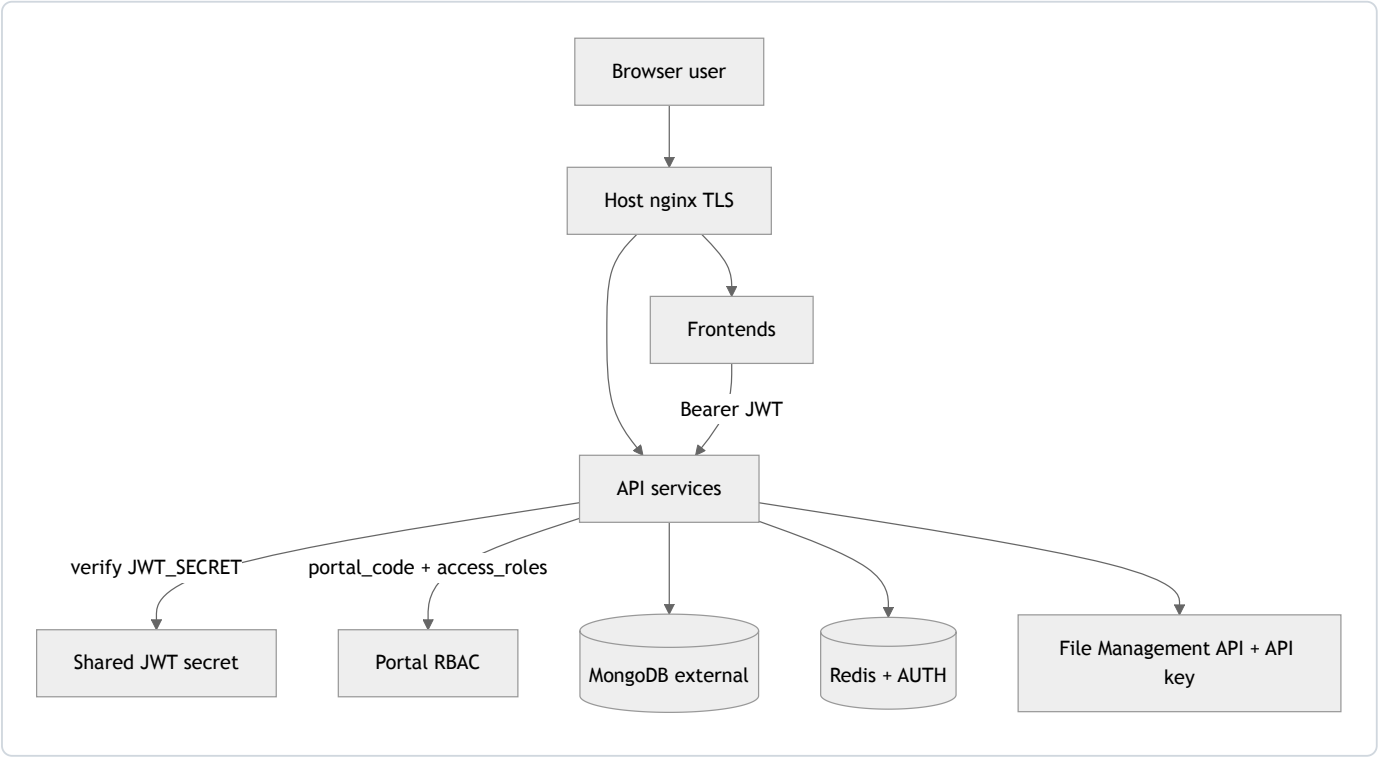
**Status:** Verified from repository implementation (Phases 0–3 hardening applied) unless marked otherwise.

**Scope:** Authentication, authorization, secrets, transport security, known risks, consolidated challenges (§11), phased improvement plan (§12), plus threat model / data-protection / authorization companion docs — not a penetration-test report.

**Sources:**

- `auth-service/` , `opms-backend/src/middlewares/` , portal middlewares (lead-manager, work-planner)
- `nginx/` `TLS + logging.conf` / `auth-rate-limit.conf` / `fail2ban` jails
- `docker-compose.yml` , `.env.docker.example` , `DOCKER.md`
- `.github/workflows/security-scans.yml`
- `docs/02-architecture/07-authentication-authorization.md`
- `docs/06-developer-deployment/19-security.md`
- Companion: [02-threat-model](#), [03-data-protection-and-ops](#), [04-authorization-model](#)

## 1. Security model overview



### Trust boundaries

| Boundary          | What crosses it                  | Control                                                      |
|-------------------|----------------------------------|--------------------------------------------------------------|
| Internet → host   | HTTPS                            | nginx TLS + HSTS snippets                                    |
| Browser → API     | REST + JWT                       | Bearer token; CORS origins                                   |
| Service → service | Internal HTTP on compose network | Shared JWT; internal notification routes require service JWT |
| Service → Mongo   | Connection string                | MONGO_URI secret                                             |

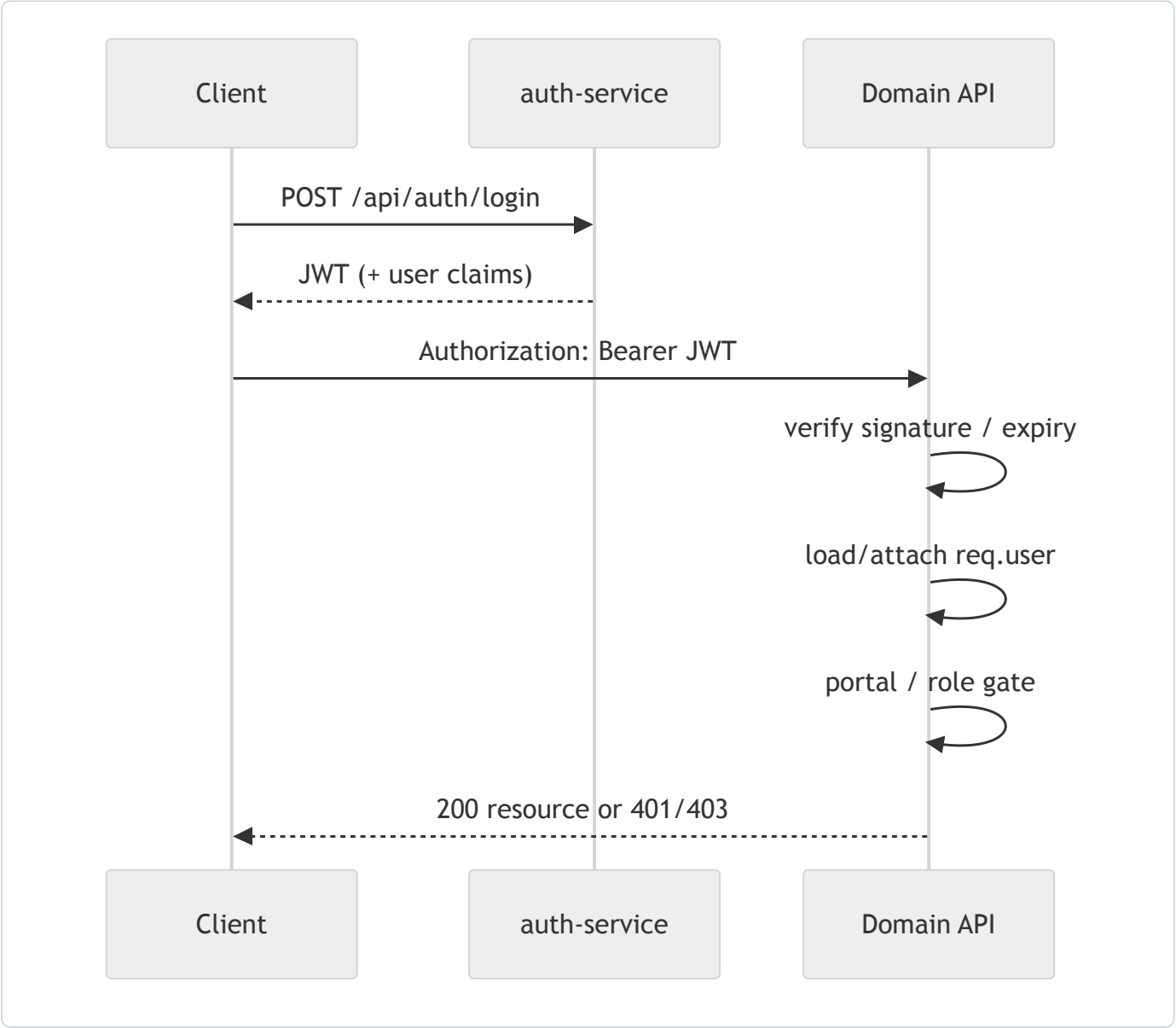
| Boundary           | What crosses it | Control                                                 |
|--------------------|-----------------|---------------------------------------------------------|
| Service → Redis    | Queue/jobs      | Redis AUTH ( REDIS_PASSWORD ); host bind 127.0.0.1 only |
| Service → File API | Uploads         | FILE_MANAGEMENT_API_KEY                                 |

## 2. Authentication

### Mechanism

- **JWT** signed with shared `JWT_SECRET` across services
- Passwords hashed with **bcrypt** ( `bcryptjs` )
- Token TTL via `JWT_EXPIRES_IN` (default **8h** )
- Optional **MASTER\_PASSWORD** : break-glass login as any user if set — **must be empty in production**
- Password policy: min **10** chars, letter + number, no spaces (create user / change password)
- Portal SSO: one-time `?handoff=` codes (legacy `?token=` still accepted)

### Login flow



## Obtain token

```
POST /api/auth/login
Content-Type: application/json

{ "email": "user@example.com", "password": "*****" }
```

Available on auth-service ( :7003 ) or via opms-backend proxy ( :7001/api/auth/login ).

## Session introspection

```
GET /api/auth/me
Authorization: Bearer <token>
```

## Frontend session handling

| App                        | Primary storage              | Notes                                                                     |
|----------------------------|------------------------------|---------------------------------------------------------------------------|
| app-frontend               | shakti.app.session + cookies | SSO hub; launches peers with one-time ?handoff=                           |
| opms-frontend              | medica.auth + cookies        | Exchanges handoff (middleware + bootstrap); legacy ?token= still accepted |
| user / lead / work planner | per-app shakti.*.session     | Middleware exchanges ?handoff= → session cookies                          |

## SSO handoff (preferred)

```
POST /api/auth/handoff
Authorization: Bearer <access-token>

→ { "code": "<one-time>", "expires_in": 60 }

POST /api/auth/handoff/exchange
Content-Type: application/json

{ "code": "<one-time>" }

→ { "token": "<jwt>", "user": { ... } }
```

**Risk note:** Prefer ?handoff= over putting JWTs in URLs. Legacy ?token= remains during rollout. SSE/file browser navigations may still append ?token= (separate from portal SSO).

Default access-token TTL is `JWT_EXPIRES_IN=8h` . Refresh tokens are not implemented — users re-login after expiry.

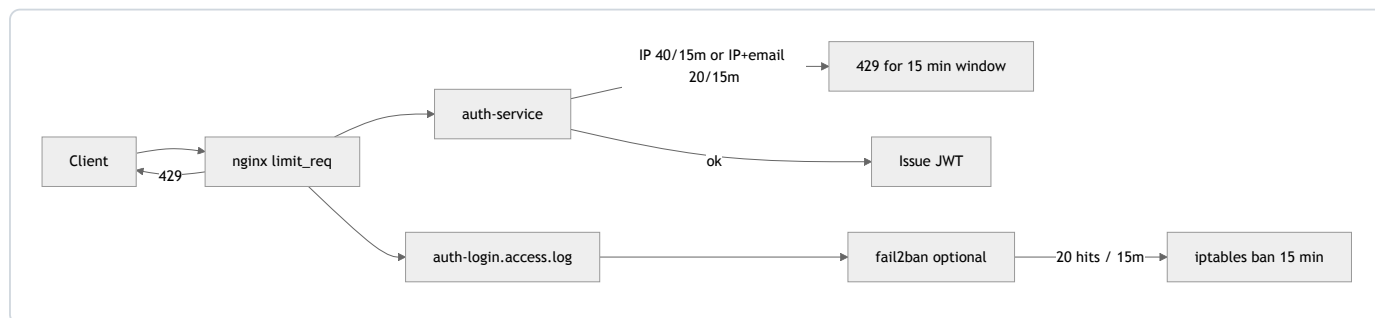
Password policy (create user / change password): **min 10 characters**, at least one letter and one number, no spaces.

## Login rate limiting & 15-minute IP block

Brute-force controls are layered (app → nginx → optional fail2ban).

| Layer    | Where                       | Rule                                                        | Effect                             |
|----------|-----------------------------|-------------------------------------------------------------|------------------------------------|
| App — IP | auth-service loginIpBlocker | 40 failed logins / 15 min per IP ( skipSuccessfulRequests ) | HTTP 429 — try again in 15 minutes |

| Layer           | Where                                             | Rule                                                                               | Effect                                                      |
|-----------------|---------------------------------------------------|------------------------------------------------------------------------------------|-------------------------------------------------------------|
| App — IP+email  | <code>loginEmailRateLimiter</code>                | 20 failed / 15 min per IP+email                                                    | HTTP 429                                                    |
| App — handoff   | <code>handoffExchangeRateLimiter</code>           | 40 / 15 min                                                                        | Protects SSO code exchange                                  |
| Edge — nginx    | <code>snippets/auth-rate-limit.conf</code>        | <code>limit_req</code> on POST <code>/api/auth/login</code> (and handoff exchange) | HTTP 429 at edge; writes <code>auth-login.access.log</code> |
| Host — fail2ban | <code>nginx/fail2ban/jail.d/opms-auth.conf</code> | 20 matches in 15 min → <b>bantime 15m</b>                                          | Hard IP ban at firewall for <b>15 minutes</b>               |



**Deploy fail2ban (ops):** copy `nginx/fail2ban/filter.d/*` and `jail.d/*` to `/etc/fail2ban/`, ensure `logging.conf` is included from `nginx http {}`, then `fail2ban-client reload`.

### 3. Authorization (RBAC)

#### Layers

1. **Authenticated** — valid JWT
2. **Portal membership** — `user.portals[]` contains required `portal_code`
3. **access\_roles** — role string must match portal gate (admin bypass where coded)
4. **Handler-level checks** — department/workflow rules for specific actions
5. **Soft-delete routes** — authenticated (+ OPMS portal) on many trash/restore endpoints

#### Portal codes and roles (observed)

| portal_code  | Seeded by default?                   | access_roles (observed)                                                                                                                  |
|--------------|--------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------|
| opms         | Yes ( <code>DEFAULT_PORTALS</code> ) | <code>super_admin</code> , <code>admin</code> , <code>sales</code> , <code>finance</code> , <code>account</code> , <code>dispatch</code> |
| work_planner | No                                   | <code>admin</code> , <code>manager</code> , <code>executive</code> (+ admin bypasses)                                                    |
| lead_manager | No                                   | <code>admin</code> , <code>manager</code> , <code>executive</code>                                                                       |
| user_manager | No                                   | <code>admin</code> , <code>super_admin</code> (FE + <code>requireUserManagerAdmin</code> on <code>/api/users*</code> )                   |

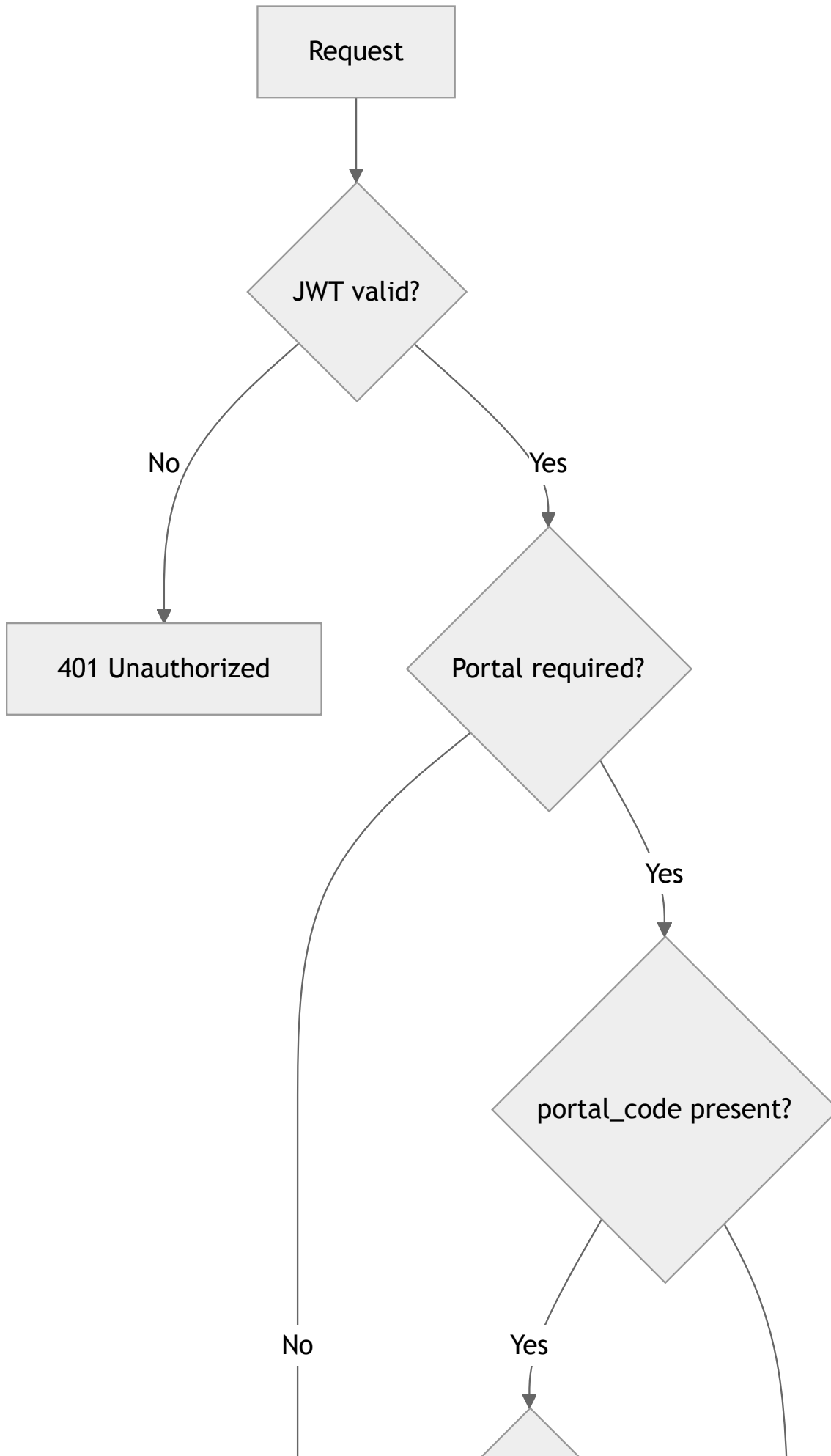
#### Middleware gates

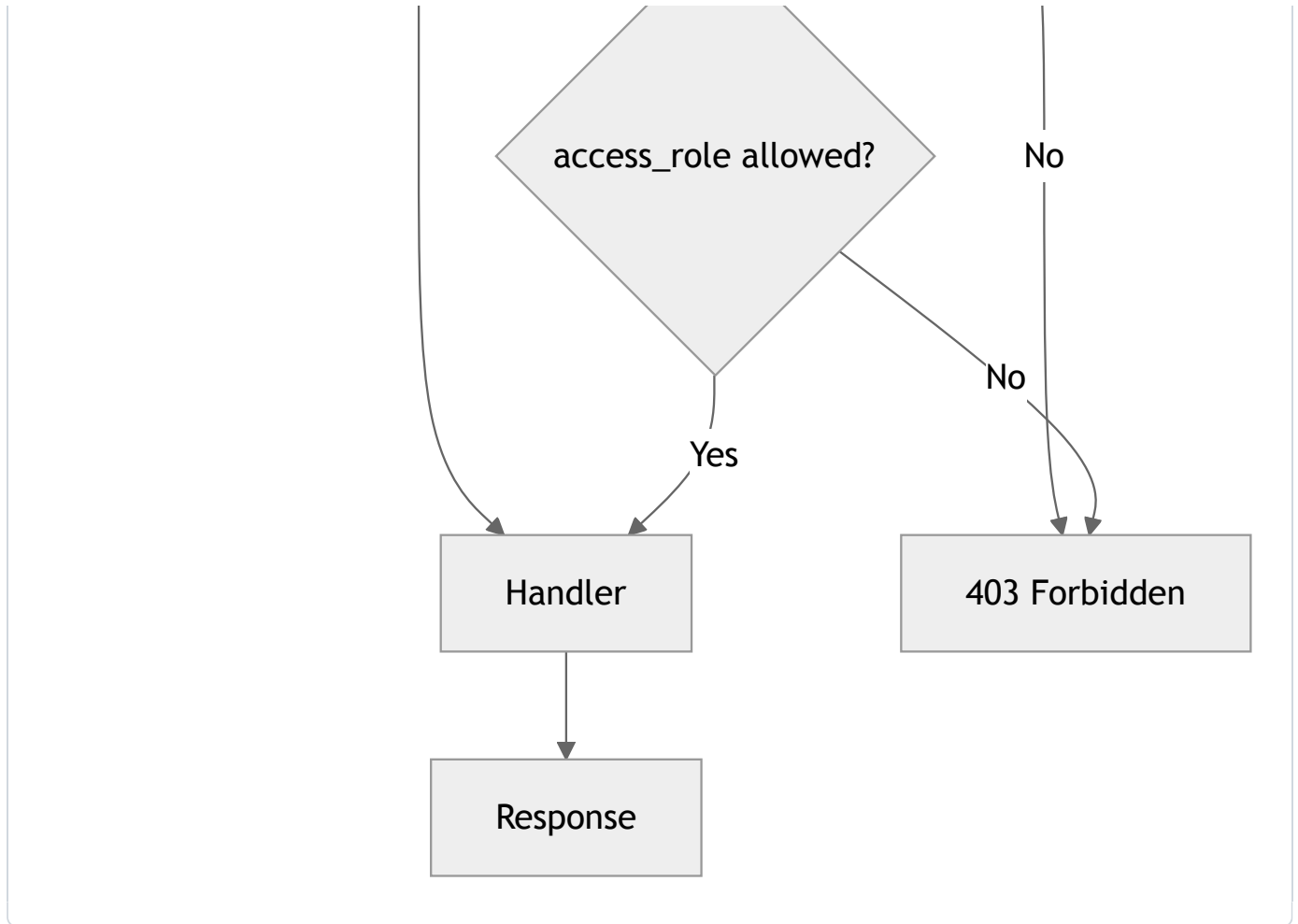
| Gate                                  | Applies to                 |
|---------------------------------------|----------------------------|
| <code>requireAuth</code>              | Most domain routes         |
| <code>requireOpmsAccess</code>        | OPMS domain APIs           |
| <code>requireLeadManagerAccess</code> | Lead Manager (most routes) |
| <code>requireWorkPlannerAccess</code> | Work Planner routes        |

| Gate                    | Applies to                                 |
|-------------------------|--------------------------------------------|
| requireUserManagerAdmin | auth-service /api/users* and roles         |
| requireInternalService  | notification /api/notifications/internal/* |
| Webhook secret          | Google Sheet ingest                        |

Missing opms portal ⇒ **403** even if department is set (documented in Swagger + middleware behavior).







## 4. Transport & edge security

### nginx (production pattern)

- TLS 1.2/1.3 via `nginx/snippets/ssl-params.conf`
- HSTS and security headers in ssl snippets
- Let's Encrypt cert paths for `*.spspl.com` / `*.medicaent.in`
- HTTP → HTTPS redirect after cert bootstrap
- SSE-specific proxy settings for notification streams
- Access log format + `limit_req zones:` `nginx/snippets/logging.conf` (include from `http {}`)
- Auth login/handoff rate limits: `nginx/snippets/auth-rate-limit.conf` on `auth.spspl.com`
- Optional fail2ban jails under `nginx/fail2ban/` (15-min IP ban)

### CORS

Configured via `CORS_ORIGINS` (comma-separated). Unknown origins are denied without Express 500.

If empty, origins are derived from `NEXT_PUBLIC_*` / public URL env vars. Local Compose `localhost:*` ports are allowed when the allowlist is empty or includes localhost (disable with `CORS_ALLOW_LOCALHOST=0`).

### Docker network

Services communicate on the Compose bridge using internal URLs ( `http://auth-service:7003`, etc.). `message-service` and `notification-service` are **not** published on the host. Internal notification routes require **service JWT**.

## 5. Secrets & configuration hygiene

| Variable                                  | Secret?     | Guidance                                         |
|-------------------------------------------|-------------|--------------------------------------------------|
| JWT_SECRET                                | Yes         | Long random; identical across all services       |
| MASTER_PASSWORD                           | Yes         | Leave <b>empty</b> in production                 |
| MONGO_URI / MONGODB_URI                   | Yes         | Atlas/user credentials                           |
| FILE_MANAGEMENT_API_KEY                   | Yes         | Uploads                                          |
| SMTP_* / Graph / WhatsApp / VAPID private | Yes         | Integrations                                     |
| GOOGLE_SHEET_WEBHOOK_SECRET               | Yes         | Webhook auth                                     |
| REDIS_PASSWORD                            | Yes         | Redis AUTH (compose <code>--requirepass</code> ) |
| SEED_PASSWORD                             | Yes         | Demo only                                        |
| NEXT_PUBLIC_*                             | No (public) | Baked into FE builds — never put secrets here    |

### Critical finding (remediated in example file)

`.env.docker.example` previously contained real-looking credentials. **It now uses placeholders only.**

#### Ops still required:

1. Rotate any secrets that may have been exposed while the old example was in git history
2. Ensure `.env.docker` remains gitignored and never committed
3. Set `REDIS_PASSWORD` and `REDIS_URL=redis://:<password>@redis:6379` in `.env.docker` before `compose up`
4. Keep `MASTER_PASSWORD` empty in production

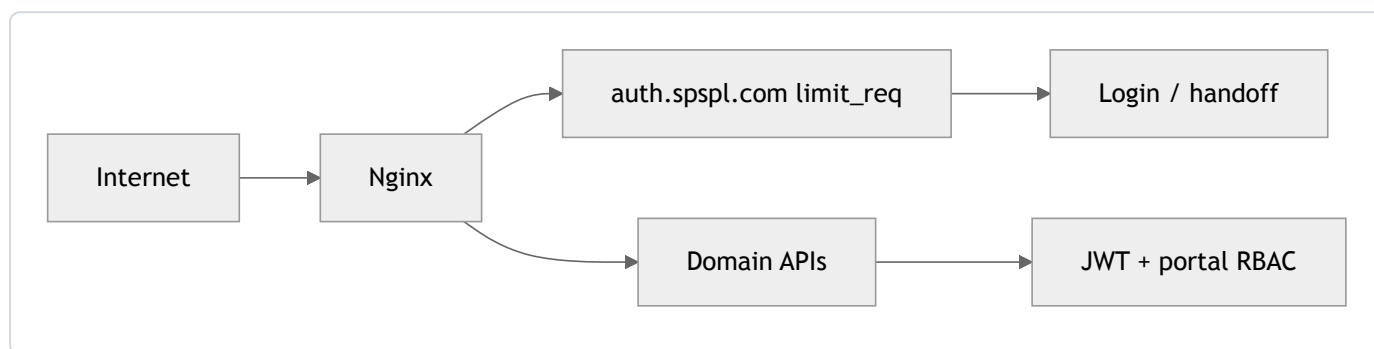
Do not re-declare `MONGO_URI` / `JWT_SECRET` under Compose `environment:` with empty interpolation — empty values override `env_file` (see `DOCKER.md`).

## 6. Public and weakly protected surfaces

Documented carefully for threat modeling. Status reflects post Phase 0–1 hardening where noted.

| Surface                                         | Auth                                                                                                                         | Risk / status                                        |
|-------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------|
| POST <code>/api/auth/login</code>               | Public + <b>rate limit</b> (40 / 15 min per IP; 20 / 15 min per IP+email) + nginx <code>limit_req</code> + optional fail2ban | Brute force mitigated at app + edge                  |
| GET <code>/api/company-info</code>              | Public = branding only; full doc when authenticated                                                                          | Hardened (no bank/tax on anonymous GET)              |
| Google Sheet webhooks                           | Shared secret                                                                                                                | Secret leakage ⇒ data injection                      |
| WhatsApp webhooks                               | Provider verify                                                                                                              | Must validate hub challenge/signature per Meta rules |
| POST <code>/api/notifications/internal/*</code> | <b>Service JWT</b> ( <code>requireInternalService</code> )                                                                   | Hardened                                             |
| opms <code>/api/terms-and-conditions</code>     | <b>requireAuth + requireOpmsAccess</b>                                                                                       | Hardened                                             |
| lead-manager <code>/api/attachments</code>      | <b>requireAuth + requireLeadManagerAccess</b>                                                                                | Hardened                                             |
| work-planner attachment view                    | <b>requireAuth + portal gate</b> ; FE may pass <code>?token=</code> for new-tab                                              | Hardened                                             |

| Surface          | Auth                                               | Risk / status |
|------------------|----------------------------------------------------|---------------|
| auth /api/users* | <code>requireAuth + requireUserManagerAdmin</code> | Hardened      |



**Ops:** rotate any historically exposed secrets; set `REDIS_PASSWORD` in live `.env.docker` ; deploy nginx snippets + optional fail2ban; keep `MASTER_PASSWORD` empty.

## 7. Data protection controls present

| Control                               | Status                                                                                               |
|---------------------------------------|------------------------------------------------------------------------------------------------------|
| Password hashing (bcrypt)             | Implemented                                                                                          |
| Password strength policy              | Min 10 + letter + number                                                                             |
| Soft-delete (recoverable)             | Many domain models                                                                                   |
| Append-only workflow history          | OrderWorkflow / status history                                                                       |
| HTTPS at edge                         | nginx configs                                                                                        |
| File binaries outside app DB          | External File Management API                                                                         |
| ActivityLog (OPMS / LM / WP)          | Actor + timestamp + IP/UA via audit context                                                          |
| Field-level encryption at rest in app | <b>Not required</b> for v1 (Atlas at-rest + bcrypt) — see <a href="#">03-data-protection-and-ops</a> |
| Public company-info projection        | Branding only when unauthenticated                                                                   |

## 8. Infrastructure security notes

| Item                   | Finding                                                                                                                                           |
|------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------|
| Redis                  | <b>AUTH</b> via <code>REDIS_PASSWORD</code> ; host port bound to <code>127.0.0.1</code> only; Compose builds <code>REDIS_URL</code> from password |
| message / notification | <b>Not published</b> to host (Compose <code>expose</code> / network only)                                                                         |
| MongoDB                | External; protect via Atlas IP allowlists / strong credentials                                                                                    |
| Containers             | Production images run as <b>USER node</b> (non-root)                                                                                              |
| CI secrets scanning    | <b>Gitleaks</b> workflow + auth-service <code>npm audit</code> ( <code>.github/workflows/security-scans.yml</code> )                              |
| nginx edge             | <code>limit_req</code> on login/handoff + dedicated access logs; optional fail2ban                                                                |

## 9. Security-related NFRs (from implementation)

| Topic                      | Status                                                                                                 |
|----------------------------|--------------------------------------------------------------------------------------------------------|
| Authentication             | JWT ( 8h default) + SSO handoff codes                                                                  |
| Authorization              | Portal RBAC + User Manager admin gate                                                                  |
| Confidentiality in transit | TLS at nginx                                                                                           |
| Rate limiting              | Login IP + IP/email (15 min); handoff exchange limit; nginx <code>limit_req</code> ; optional fail2ban |
| Secrets scanning           | Gitleaks CI                                                                                            |
| Threat model notes         | <a href="#">02-threat-model.md</a>                                                                     |
| Centralized WAF            | <b>Not identified</b> (ops backlog)                                                                    |
| Formal pen-test            | Scope listed; scheduling <b>pending</b>                                                                |
| MFA                        | <b>Deferred</b> (IdP vs TOTP)                                                                          |

## 10. Incident checklist (ops-oriented)

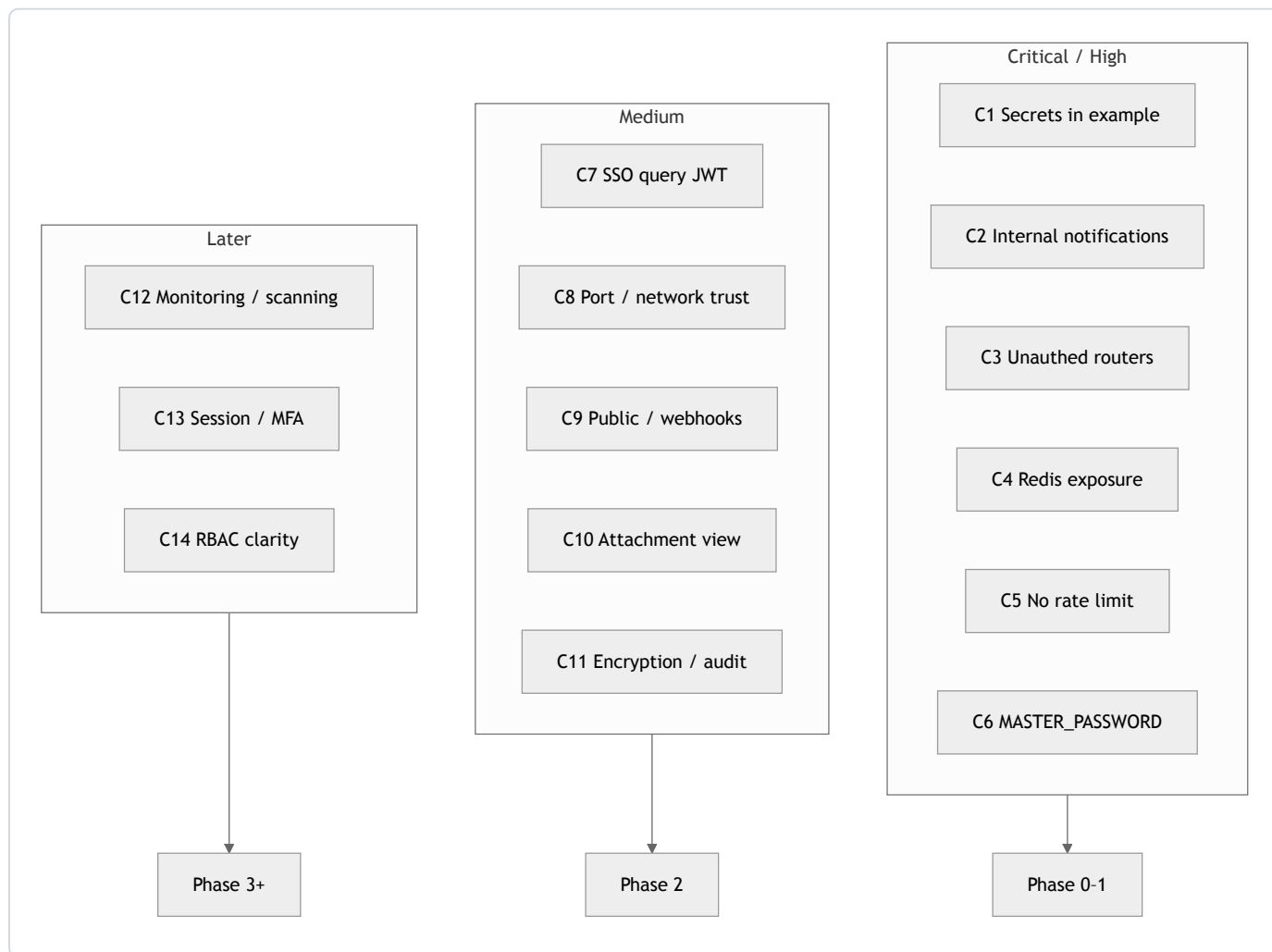
1. Rotate `JWT_SECRET` → forces re-login everywhere (coordinate downtime)
2. Rotate Mongo, File API, Graph, WhatsApp, VAPID, webhook secrets
3. Clear `MASTER_PASSWORD` in production env
4. Review nginx `auth-login.access.log` / fail2ban for brute-force (429 spikes)
5. Restart services after secret rotation: `docker compose --env-file .env.docker up -d`
6. Rebuild frontends if any `NEXT_PUBLIC_*` changed
7. Confirm login IP block still returns 429 for 15 minutes after abuse tests

## 11. Security challenges (consolidated)

Challenges below are derived from §§2–9. Severity is relative to a typical internet-facing Compose + nginx deployment.

| ID  | Challenge                                                                      | Severity        | Status                                                                       | Evidence   |
|-----|--------------------------------------------------------------------------------|-----------------|------------------------------------------------------------------------------|------------|
| C1  | Example/env hygiene — real-looking secrets in <code>.env.docker.example</code> | <b>Critical</b> | Example sanitized; <b>rotate if exposed</b>                                  | §5         |
| C2  | Unauthenticated internal notification create routes                            | <b>High</b>     | <b>Mitigated</b> (service JWT)                                               | §6         |
| C3  | Unauthenticated terms / lead attachments routers                               | <b>High</b>     | <b>Mitigated</b>                                                             | §6         |
| C4  | Redis without AUTH + host port published                                       | <b>High</b>     | <b>Mitigated</b> (AUTH + localhost bind)                                     | §8         |
| C5  | No login rate limiting / account lockout                                       | <b>High</b>     | <b>Mitigated</b> (app 15-min windows + nginx + optional fail2ban 15-min ban) | §2, §6, §9 |
| C6  | <code>MASTER_PASSWORD</code> break-glass if set in production                  | <b>High</b>     | <b>Ops:</b> keep empty                                                       | §2, §5     |
| C7  | JWT SSO handoff via <code>?token=</code> query string                          | <b>Medium</b>   | <b>Mitigated</b> ( <code>?handoff=</code> ; legacy token still accepted)     | §2         |
| C8  | Published API ports / network trust                                            | <b>Medium</b>   | <b>Mitigated</b> (message/notification unpublished)                          | §4, §6     |
| C9  | Public <code>company-info</code> / webhook surfaces                            | <b>Medium</b>   | <code>company-info</code> slimmed; webhooks still secret-dependent           | §6         |
| C10 | Work-planner attachment view before auth                                       | <b>Medium</b>   | <b>Mitigated</b> (behind auth)                                               | §6         |

| ID  | Challenge                                    | Severity   | Status                                                        | Evidence |
|-----|----------------------------------------------|------------|---------------------------------------------------------------|----------|
| C11 | Field encryption / audit coverage            | Medium     | Audit IP/UA done; app field encryption not required v1        | §7       |
| C12 | No CI secrets scanning / threat notes        | Low–Medium | Mitigated (gitleaks + threat model doc); WAF/pen-test pending | §8, §9   |
| C13 | Long JWT TTL / no MFA / no password policy   | Low–Medium | Partial (8h + password policy); MFA deferred                  | §2       |
| C14 | Portal RBAC gaps / Permission-code ambiguity | Low        | Decided (portal roles; user_manager gated)                    | §3       |



## 12. Security improvement plan

**Goal:** Close Critical/High findings first, shrink the trusted network, then raise authn/authz and ops maturity.

**Owners (suggested):** Ops = deploy/env; Backend = API middleware/routes; Frontend = SSO/session; Product = intent decisions in §13.

### Phase 0 — Immediate (ops, days)

| Action                                                                            | Addresses | Owner | Status      | Acceptance criteria                                    |
|-----------------------------------------------------------------------------------|-----------|-------|-------------|--------------------------------------------------------|
| Rotate all credentials that may have appeared in <code>.env.docker.example</code> | C1        | Ops   | Ops pending | New secrets live; old ones revoked; services restarted |

| Action                                                                                                         | Addresses | Owner         | Status                                                                                | Acceptance criteria                                                                  |
|----------------------------------------------------------------------------------------------------------------|-----------|---------------|---------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------|
| Sanitize <code>.env.docker.example</code> to placeholders only; confirm <code>.env.docker</code> is gitignored | C1        | Ops + Backend | <b>Done</b> (example sanitized)                                                       | Example file has no real values; <code>git check-ignore -v .env.docker</code> passes |
| Ensure production <code>MASTER_PASSWORD</code> is empty / unset                                                | C6        | Ops           | <b>Ops pending</b>                                                                    | Login with master password fails in prod                                             |
| Redis <code>requirepass</code> + bind <code>127.0.0.1</code> ; wire <code>REDIS_URL</code>                     | C4        | Ops + Backend | <b>Done</b> in compose (set <code>REDIS_PASSWORD</code> in <code>.env.docker</code> ) | Port not reachable from untrusted networks; AUTH required                            |
| Unpublish notification/message host ports                                                                      | C2, C8    | Backend       | <b>Done</b> in compose                                                                | Internal routes not reachable from internet via host ports                           |

## Phase 1 — Authz gaps on weak surfaces (backend, 1–2 sprints)

| Action                                                                                      | Addresses | Owner              | Status                        | Acceptance criteria                                                       |
|---------------------------------------------------------------------------------------------|-----------|--------------------|-------------------------------|---------------------------------------------------------------------------|
| Protect <code>POST /api/notifications/internal/*</code> with service JWT                    | C2        | Backend            | <b>Done</b>                   | Unauthenticated create returns 401/403; callers send Bearer service token |
| Add <code>requireAuth</code> + portal gate to opms <code>/api/terms-and-conditions</code>   | C3        | Backend            | <b>Done</b>                   | Anonymous read/write fails                                                |
| Add <code>requireAuth</code> / portal gate to lead-manager <code>/api/attachments</code>    | C3        | Backend            | <b>Done</b>                   | Anonymous attachment ops fail                                             |
| Work-planner attachment view behind auth; FE appends <code>?token=</code> for new-tab opens | C10       | Backend + Frontend | <b>Done</b>                   | Anonymous view fails; authenticated users can open files                  |
| Login rate limiting (IP + email) on auth-service                                            | C5        | Backend            | <b>Done</b>                   | Sustained brute force yields 429                                          |
| Login IP block (40 / 15 min) + fail2ban jail for hard 15-min ban                            | C5        | Backend + Ops      | <b>Done</b> (deploy fail2ban) | IP blocked for 15 min after abuse                                         |
| Validate WhatsApp webhook signature per Meta; rotate Google Sheet webhook secret            | C9        | Backend + Ops      | <b>Partial / ops</b>          | Invalid signature/secret rejected                                         |

## Phase 2 — Session & transport hardening (1–2 sprints)

| Action                                                                                                                                                  | Addresses | Owner              | Status                                                   | Acceptance criteria                                        |
|---------------------------------------------------------------------------------------------------------------------------------------------------------|-----------|--------------------|----------------------------------------------------------|------------------------------------------------------------|
| Replace SSO <code>?token=</code> with one-time handoff code ( <code>POST /api/auth/handoff</code> + <code>/exchange</code> ); peers exchange then strip | C7        | Frontend + Backend | <b>Done</b> (legacy <code>?token=</code> still accepted) | Token not required in durable URL; handoff single-use ~60s |
| Shorten access-token TTL to 8h (cookie <code>maxAge</code> aligned); refresh tokens deferred                                                            | C13       | Backend + Frontend | <b>Done</b> (TTL); refresh <b>deferred</b>               | Access token hours not days                                |
| Enforce password min 10 + letter + number on create/change                                                                                              | C13       | Backend            | <b>Done</b>                                              | Weak passwords rejected                                    |
| CORS allowlist from <code>CORS_ORIGINS</code> ; fail closed in production if unset                                                                      | C8        | Backend            | <b>Done</b>                                              | Unknown origins blocked; prod requires config              |
| Public <code>GET /api/company-info</code> returns branding fields only; full doc when authenticated                                                     | C9        | Backend            | <b>Done</b>                                              | No bank/tax fields on anonymous GET                        |

Phase 3 — Data protection, RBAC clarity, observability

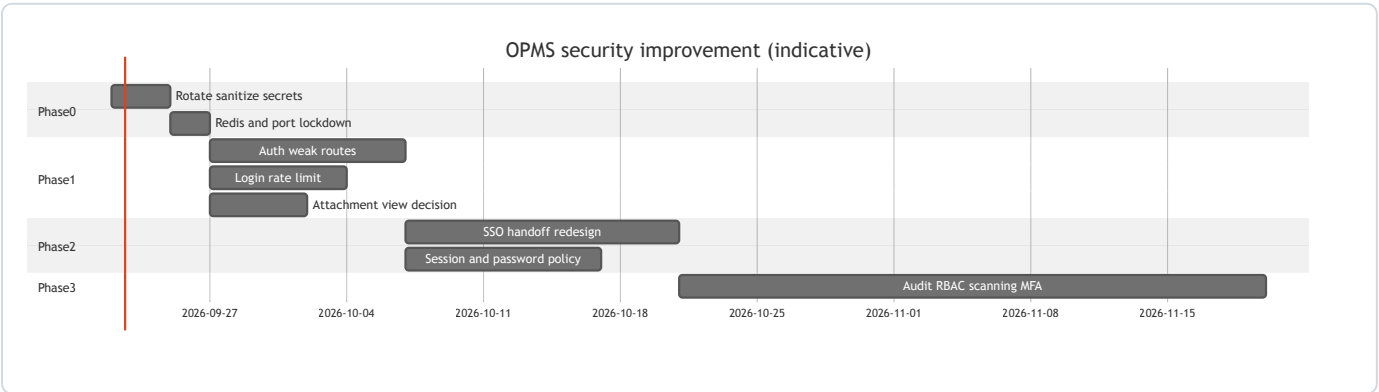
| Action                                                                                                           | Addresses | Owner          | Status                 | Acceptance criteria                                        |
|------------------------------------------------------------------------------------------------------------------|-----------|----------------|------------------------|------------------------------------------------------------|
| Harden ActivityLog with request IP/UA (LM / WP / OPMS via AsyncLocalStorage)                                     | C11       | Backend        | Done                   | Mutations capture actor + timestamp + IP/UA when available |
| Portal access_roles is authz source of truth; Permission codes deferred; user_manager admin gated on /api/users* | C14       | Backend + Docs | Done                   | See <a href="#">04-authorization-model.md</a>              |
| Document Atlas IP allowlists, backup encryption, app-level field encryption stance                               | C11       | Docs           | Done                   | See <a href="#">03-data-protection-and-ops.md</a>          |
| Gitleaks CI + npm audit job; .gitleaks.toml                                                                      | C12       | Backend + Ops  | Done                   | .github/workflows/security-scans.yml                       |
| nginx login/handoff limit_req + access logs                                                                      | C5, C12   | Ops            | Done (deploy snippets) | nginx/snippets/logging.conf + auth-rate-limit.conf         |
| Lightweight threat model notes; pen-test scope listed                                                            | C12       | Docs           | Done                   | <a href="#">02-threat-model.md</a>                         |
| MFA evaluation for admin / super_admin                                                                           | C13       | Product        | Deferred (IdP vs TOTP) | Decision recorded in data-protection doc                   |
| Non-root USER node on production Dockerfiles                                                                     | C12       | Ops            | Done                   | All prod images run as node                                |

Priority order (execution sequence)

- 1. Phase 0 — sanitize example / Redis / ports; ops still: rotate secrets + set REDIS\_PASSWORD + clear MASTER\_PASSWORD
- 2. Phase 1 — auth weak routers / rate limit / attachment view; WhatsApp signature hardening remaining
- 3. Phase 2 — SSO handoff / 8h JWT / password policy / CORS / slim company info; refresh tokens deferred
- 4. Phase 3 — audit IP/UA / RBAC docs / scanning / nginx limits / non-root / threat notes; MFA + pen-test scheduling remaining

Tracking

| Field              | Suggestion                                                                                          |
|--------------------|-----------------------------------------------------------------------------------------------------|
| Backlog            | MFA IdP decision; pen-test scheduling; WhatsApp signature validation                                |
| Definition of done | Acceptance criteria in tables above + docs updated when behavior changes                            |
| Verify             | Re-check route files and compose publish list after each phase; refresh this document's Status line |



---

## 13. Requires confirmation (product / security team)

1. Is work-planner public attachment view intentional? (*resolved: secured behind auth; FE uses `?token=` for new-tab*)
  2. Should non- `opms` portals be seeded by default?
  3. Is Permission-code RBAC (`opms` Permission model) still a goal vs portal roles only? (*C14 — **decided: portal roles; Permission codes deferred***)
  4. Target password policy / session length / MFA — password + 8h done; **MFA deferred to IdP decision** (*C13*)
  5. Who owns secret rotation and env hygiene for `.env.docker.example` ? (*C1 / Phase 0 — example sanitized; rotation still Ops*)
  6. Are notification and attachment services intended to be reachable only via nginx, or also via published host ports? (*resolved: compose no longer publishes message/notification*)
- 

## Related documents

- [Threat model notes](#)
- [Data protection & ops](#)
- [Authorization model](#)
- [Authentication & Authorization \(Architecture\)](#)
- [API Authentication](#)
- [Functional: Authentication](#)
- [Environment Variables](#)
- [Security \(developer-deployment summary\)](#)
- [Troubleshooting](#)
- [Documentation Audit](#)

## Phase 3 — Threat model notes (lightweight)

**Status:** Working draft reflecting Phases 0–3 hardening. Not a formal pen-test.

**Last updated:** 2026-09-22

### Assets

| Asset                                            | Sensitivity |
|--------------------------------------------------|-------------|
| JWT / <code>JWT_SECRET</code>                    | Critical    |
| MongoDB (orders, parties, users, leads, plans)   | High        |
| File Management API key + binaries               | High        |
| Redis queues                                     | Medium      |
| Company bank fields (authenticated company-info) | High        |
| Webhook secrets (Google Sheet, WhatsApp)         | High        |

### Trust boundaries

1. Internet → nginx TLS (+ login `limit_req` / optional fail2ban)
2. Browser → APIs (JWT + portal RBAC)
3. Compose network (service JWT for notifications/emails)
4. External Mongo / File API

### Top threats (STRIDE-lite)

| Threat                            | Mitigation (current)                                                                                                                       | Residual                                   |
|-----------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------|
| Credential stuffing on login      | App: <b>40 failed / 15 min per IP + 20 / 15 min per IP+email</b> → 429; nginx <code>limit_req</code> ; optional <b>fail2ban 15-min ban</b> | WAF / SIEM alerts                          |
| Stolen JWT in URL                 | SSO <code>?handoff=</code> one-time codes; legacy <code>?token=</code> deprecated                                                          | Remove legacy token accept; refresh tokens |
| Unauthenticated internal APIs     | Service JWT + unpublished ports                                                                                                            | mTLS later                                 |
| Secret leakage in git             | Sanitized <code>.env.docker.example</code> + gitleaks CI                                                                                   | Rotate historical secrets                  |
| Privilege escalation on user APIs | <code>requireUserManagerAdmin</code> on <code>/api/users*</code>                                                                           | Align portal seeding                       |
| Redis exposure                    | AUTH + localhost bind                                                                                                                      | Strong unique password in prod             |
| XSS → session theft               | Existing FE hygiene (out of scope here)                                                                                                    | CSP headers at nginx                       |

### Recommended pen-test scope (when scheduled)

1. Auth: login rate limits / 15-min IP block, handoff exchange, master password absent
2. Portal RBAC bypass across OPMS / LM / WP / user-manager
3. IDOR on attachments / work-plan files
4. Webhook forgery

Owners

| Area                         | Owner              |
|------------------------------|--------------------|
| Secret rotation              | Ops                |
| nginx / TLS / fail2ban / WAF | Ops                |
| Authz middleware             | Backend            |
| Pen-test scheduling          | Product + Security |

## Phase 3 — Data protection & ops controls

### MongoDB (Atlas / external)

| Control                    | Guidance                                                                                              |
|----------------------------|-------------------------------------------------------------------------------------------------------|
| Network                    | Restrict to host / VPC IP allowlist; prefer private endpoint                                          |
| Auth                       | Strong DB user passwords; no shared admin from apps                                                   |
| Encryption at rest         | Atlas default encryption ON; customer KMS optional                                                    |
| Backups                    | Atlas continuous backup / snapshots; test restore quarterly                                           |
| App-level field encryption | <b>Not required</b> for v1 unless Product mandates PII-at-rest beyond Atlas; passwords already bcrypt |

### Redis

| Control                 | Status                                                             |
|-------------------------|--------------------------------------------------------------------|
| AUTH ( REDIS_PASSWORD ) | Required in Compose                                                |
| Host publish            | 127.0.0.1 only                                                     |
| Persistence             | Volume <code>redis_data</code> ; treat as ephemeral queues + cache |

### Application PII

Sensitive company bank / tax fields are returned only to **authenticated** callers of `GET /api/company-info` . Public GET is branding-only.

### Login abuse controls (rate limit + 15-min IP block)

| Control     | Detail                                                                                                                     |
|-------------|----------------------------------------------------------------------------------------------------------------------------|
| Application | <code>auth-service</code> — IP blocker 40/15m (failed only); IP+email 20/15m; returns <b>429</b> until window elapses      |
| nginx       | <code>limit_req</code> on <code>/api/auth/login</code> and <code>/api/auth/handoff/exchange</code> ; dedicated access logs |
| fail2ban    | Jail <code>opms-auth-login</code> : maxretry 20 / findtime 15m / <b>bantime 15m</b>                                        |

Successful logins do not count toward the app IP/email windows ( `skipSuccessfulRequests: true` ).

### MFA (decision)

| Option                                                  | Recommendation                                |
|---------------------------------------------------------|-----------------------------------------------|
| TOTP for <code>super_admin</code> / User Manager admins | <b>Backlog</b> — implement after IdP decision |
| SSO IdP (Google/Microsoft Entra)                        | Preferred long-term for admin portals         |
| Current                                                 | Password + JWT 8h; no MFA in codebase         |

Product should choose IdP vs in-app TOTP before build.

## Container hardening

Production images run as `USER node` (non-root). Read-only root filesystem is not enabled yet (Next.js / Node need writable tmp).

## Authorization model (Phase 3 decision)

### Source of truth: portal `access_roles`

OPMS and satellite portals authorize with:

1. Valid JWT ( `requireAuth` )
2. `user.portals[]` contains required `portal_code`
3. `access_roles` on that portal membership (plus coded admin bypasses)

| portal_code  | Typical access_roles                                       |
|--------------|------------------------------------------------------------|
| opms         | super_admin , admin , sales , finance , account , dispatch |
| work_planner | admin , manager , executive                                |
| lead_manager | admin , manager , executive                                |
| user_manager | admin , super_admin (FE + auth-service /api/users* gate)   |

### Permission-code RBAC (opms Permission / Role collections)

**Deferred / legacy.** `requirePermissions` in opms-backend currently aliases `requireAuth` and does **not** enforce permission codes. Do not build new features on Permission codes until Product re-opens that initiative.

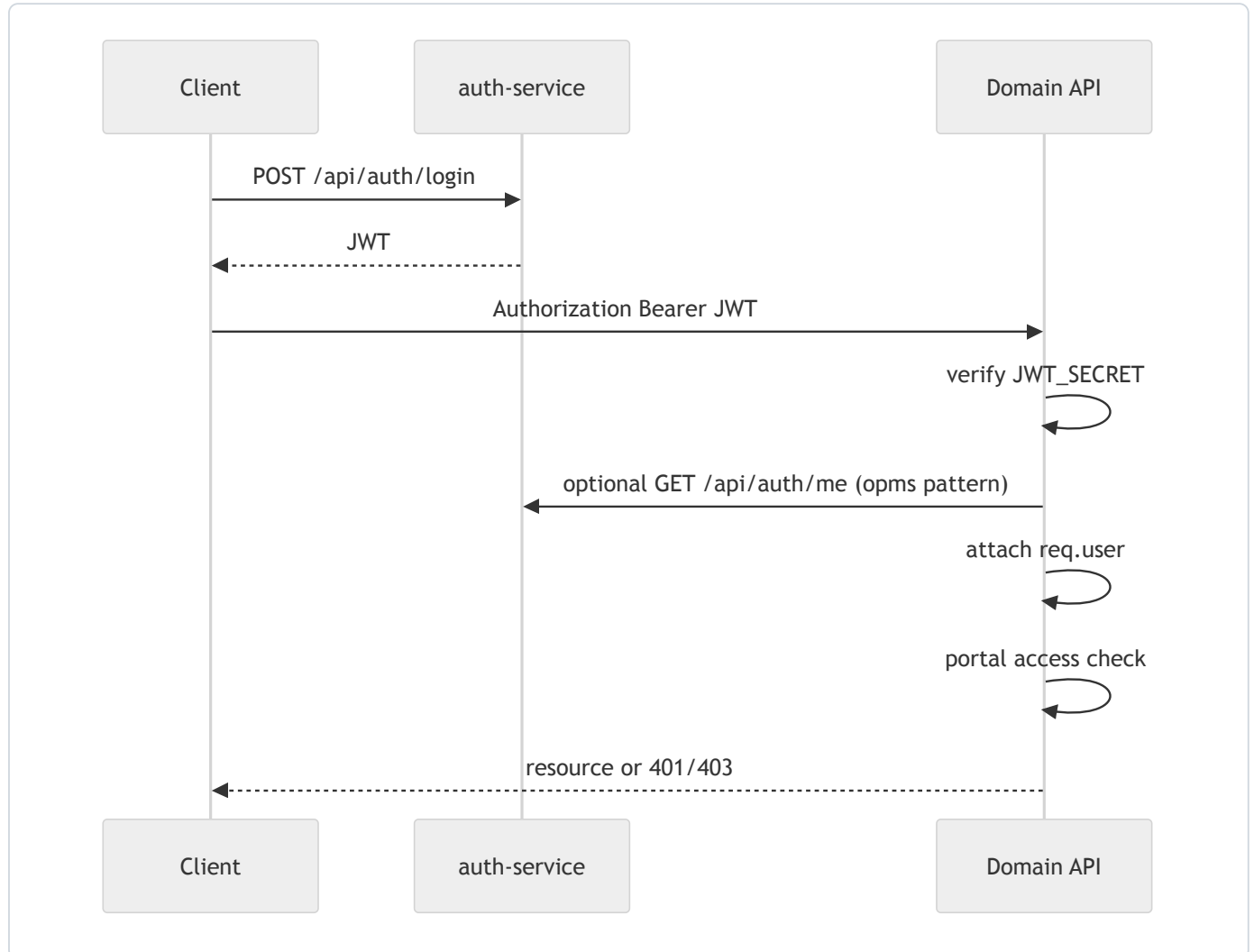
### User Manager

- Frontend: `hasSuperAdminAccess()`
- Backend: `requireUserManagerAdmin` on all `/api/users` and `/api/users/roles*` routes

Any authenticated user without admin/user\_manager admin roles receives **403**.

# Authentication & Authorization

## Authentication flow



## Token

- Signed with `JWT_SECRET`
- Expiry `JWT_EXPIRES_IN` (example default `7d`)
- Optional `MASTER_PASSWORD` break-glass (**dangerous if set in prod**)

## Authorization layers

1. **Authenticated** — valid JWT
2. **Portal membership** — `portals[]` contains required `portal_code`
3. **access\_roles** — role string must match portal gate (or admin bypass where coded)
4. **Handler-level checks** — department / role for specific actions (workflow rules, lead admin routes)
5. **Soft-delete permission** — authenticated (+ opms) for trash/restore on some routes; swagger mentions permission codes that may be aspirational vs portal model — **Requires confirmation** for fine-grained permission codes vs portal roles

## OPMS roles

super\_admin | admin | sales | finance | account | dispatch

## Cross-portal

Lead list may allow work\_planner access in some routes ( `requireLeadManagerOrWorkPlannerAccess` ).

## Public / weakly protected surfaces (document carefully)

| Surface                          | Notes                          |
|----------------------------------|--------------------------------|
| POST /api/auth/login             | Public                         |
| GET /api/company-info            | Public on auth-service         |
| Google Sheet webhooks            | Secret header/param            |
| WhatsApp webhooks                | Public verify/receive          |
| notification internal POSTs      | No requireAuth — service trust |
| opms terms-and-conditions router | No requireAuth on router       |
| lead attachments router          | No requireAuth on router       |
| work-planner attachment view     | Public view path before auth   |

See [Security](#).

# API Authentication

## Method

**Bearer JWT** in `Authorization: Bearer <token>` header.

## Obtain token

```
POST /api/auth/login
Content-Type: application/json

{ "email": "user@example.com", "password": "*****" }
```

Hit auth-service ( :7003 ) or via opms-backend proxy ( :7001/api/auth/login ).

## Session introspection

```
GET /api/auth/me
Authorization: Bearer <token>
```

## Authorization

| Gate                                  | Applies to                        |
|---------------------------------------|-----------------------------------|
| <code>requireAuth</code>              | Most domain routes                |
| <code>requireOpmsAccess</code>        | OPMS domain on opms-backend       |
| <code>requireLeadManagerAccess</code> | Lead Manager mutating/list routes |
| <code>requireWorkPlannerAccess</code> | Work Planner routes               |
| Webhook secrets                       | Google Sheet / WhatsApp verify    |

## Portal requirement (OPMS)

User must include `portals[]` entry `{ portal_code: "opms", access_roles: [...] }.`

## Related

- [Architecture Auth](#)

## Module: Authentication

---

### Purpose

Authenticate users, issue JWTs, expose current user profile, and support password change.

### Actors

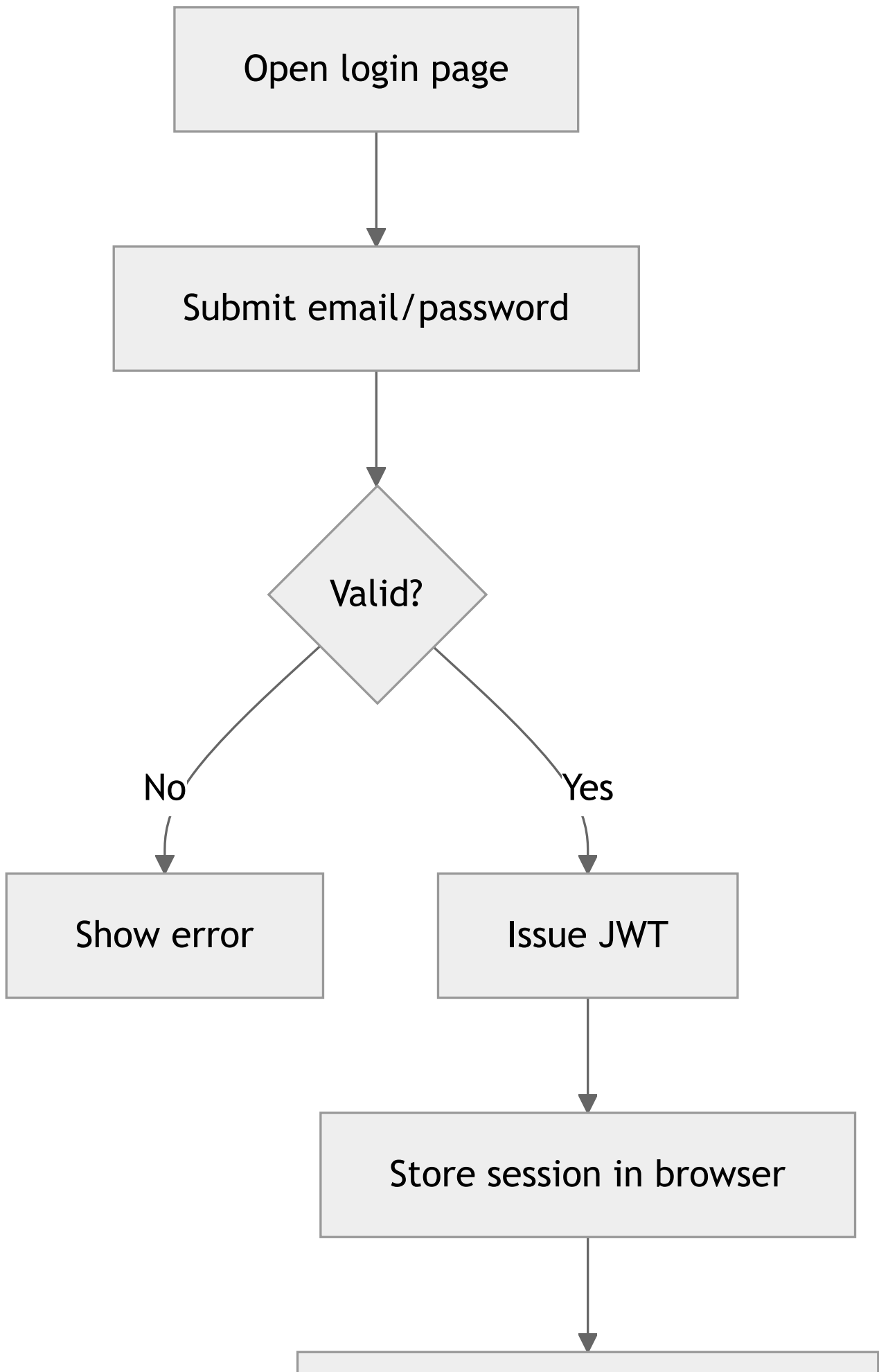
Any user with an active auth-service account; App Frontend and all portal frontends.

### Preconditions

- auth-service running and Mongo reachable
- User exists with password hash; `is_active` true (**Inferred** inactive users rejected — verify service)

## Workflow





```
graph TD; A[Navigate dashboard/portal] --> B[Optional SSO ?token= to other app];
```

Navigate dashboard/portal

Optional SSO ?token= to other app

## Business Rules

- Shared `JWT_SECRET` across services
- Optional `MASTER_PASSWORD` can authenticate as any user if set — **must be empty in production**

## Validations

Email/password required on login (controller-level).

## Permissions

Login public; `/me` and change-password require auth.

## Exceptions / Errors

401 invalid credentials; 401/403 on protected routes without/with wrong token.

## Related APIs

- `POST /api/auth/login`
- `GET /api/auth/me`
- `POST /api/auth/change-password`

## Related DB

User, Role, Portal, Department, CompanyInfo (auth-service)

## Related UI

app-frontend `/` , portal `/login` pages

## Dependencies

auth-service; MongoDB; frontends

## Source

```
auth-service/src/modules/auth/
```

# Security

## Implemented

- JWT auth + bcrypt passwords + password strength policy (min 10, letter+number)
- Portal RBAC ( `access_roles` ); User Manager admin gate on `/api/users*`
- HTTPS via nginx TLS configs; auth login/handoff edge rate limits + optional fail2ban 15-min IP ban
- Webhook secrets for Google Sheets
- Soft-delete vs hard-delete for many records
- Login rate limiting (auth-service: **40 failed / 15 min per IP + 20 / 15 min per IP+email** → 429)
- nginx `limit_req` on login/handoff + optional **fail2ban 15-minute IP ban**
- SSO one-time handoff codes
- Service JWT on notification `/api/notifications/internal/*`
- Auth on terms / attachments / work-planner attachment view
- Redis AUTH + localhost-only host publish; message/notification not host-published
- ActivityLog IP/UA via request audit context (OPMS / LM / WP)
- Production containers run as non-root `USER node`
- GitLeaks CI workflow ( `.github/workflows/security-scans.yml` )
- `.env.docker.example` placeholders only

## Remaining / deferred

| Risk                            | Notes                                         |
|---------------------------------|-----------------------------------------------|
| Historical secrets in git       | Rotate if old example was ever pushed         |
| <code>MASTER_PASSWORD</code>    | Must stay empty in prod (ops)                 |
| Legacy SSO <code>?token=</code> | Still accepted; prefer <code>?handoff=</code> |
| MFA                             | Deferred — IdP vs TOTP decision               |
| Formal pen-test                 | Scope in <a href="#">threat model</a>         |
| WAF / centralized alerting      | Ops — watch auth-login access logs            |

## Improvement plan

[Security Overview §11–§12](#) · [Threat model](#) · [Data protection](#) · [Authorization](#)

## Related

- [Security overview](#)
- [Auth architecture](#)

## Environment Variables

**IMPORTANT:** Never copy real secrets into documentation.

`.env.docker.example` uses **placeholders only**. Rotate any credentials that may have been committed historically.

| Variable                    | Required                | Purpose                   | Example (placeholder)           | Secret               |
|-----------------------------|-------------------------|---------------------------|---------------------------------|----------------------|
| NODE_ENV                    | yes                     | Runtime mode              | production                      | no                   |
| JWT_SECRET                  | <b>yes</b>              | JWT signing               | change-me-long-random           | <b>yes</b>           |
| JWT_EXPIRES_IN              | no                      | Token TTL                 | 8h                              | no                   |
| MASTER_PASSWORD             | no                      | Break-glass login         | empty in prod                   | <b>yes</b>           |
| JSON_BODY_LIMIT             | no                      | Body size                 | 50mb                            | no                   |
| MONGO_URI / MONGODB_URI     | <b>yes</b>              | Mongo connection          | mongodb+srv://USER:PASS@host/db | <b>yes</b>           |
| MONGODB_LOOKUP_FAMILY       | no                      | Prefer IPv4               | 4                               | no                   |
| REDIS_PASSWORD              | <b>yes</b><br>(compose) | Redis AUTH                | replace-with-redis-password     | <b>yes</b>           |
| REDIS_URL                   | <b>yes</b><br>(compose) | Redis (with password)     | redis://:PASSWORD@redis:6379    | <b>yes*</b>          |
| REDIS_PORT                  | no                      | Localhost publish         | 7014                            | no                   |
| *_PORT                      | no                      | Host ports                | see compose defaults            | no                   |
| AUTH_SERVICE_URL etc.       | no                      | Internal URLs             | http://auth-service:7003        | no                   |
| API_PUBLIC_BASE_URL         | prod                    | Public API                | https://api-opms.example.com    | no                   |
| NEXT_PUBLIC_*               | prod                    | Browser URLs (build-time) | https://...                     | no                   |
| CORS_ORIGINS                | prod                    | Extra CORS                | comma URLs                      | no                   |
| COMPANY_NAME / LOGO         | no                      | Branding fallback         | —                               | no                   |
| SEED_*                      | no                      | Seed controls             | —                               | SEED_PASSWORD<br>yes |
| FOLLOWUP_REMINDER_*         | no                      | Lead cron                 | —                               | no                   |
| FILE_MANAGEMENT_API_URL/KEY | optional                | Uploads                   | —                               | key <b>yes</b>       |
| SMTP_*                      | optional                | Email                     | —                               | pass <b>yes</b>      |
| MICROSOFT_GRAPH_*           | optional                | Email                     | —                               | secret <b>yes</b>    |

| Variable                                                                             | Required | Purpose            | Example (placeholder) | Secret             |
|--------------------------------------------------------------------------------------|----------|--------------------|-----------------------|--------------------|
| WHATSAPP_*                                                                           | optional | WhatsApp           | —                     | <b>yes</b>         |
| VAPID_*                                                                              | optional | Web push           | —                     | private <b>yes</b> |
| GOOGLE_SHEET_WEBHOOK_SECRET                                                          | optional | Webhooks           | —                     | <b>yes</b>         |
| ADMIN_EMAIL / ACCOUNT_EMAIL /<br>FINANCE_EMAIL / DUE_SHEET_EMAIL<br>/ DISPATCH_EMAIL | optional | Role<br>mailboxes  | —                     | no                 |
| COMPOSE_PROJECT_NAME /<br>ENV_FILE                                                   | no       | Multi-stack        | —                     | no                 |
| APP_LOGIN_URL /<br>LEAD_MANAGER_PUBLIC_URL /<br>FRONTEND_URL                         | optional | Links in<br>emails | —                     | no                 |

\* Redis requires AUTH in compose ( `--requirepass` ). Host port is bound to `127.0.0.1` only. message-service and notification-service are not published on the host.

Source: `.env.docker.example` , service `env.js` files, compose.